Domain Name System (DNS) Security

DNS: Domain Name System

People: many identifiers:

- SSN, name, passport #

Internet hosts, routers:

- IP address (32 bit) – 128.119.40.12
  unique ID
- “name”, e.g., www.yahoo.com - used by humans

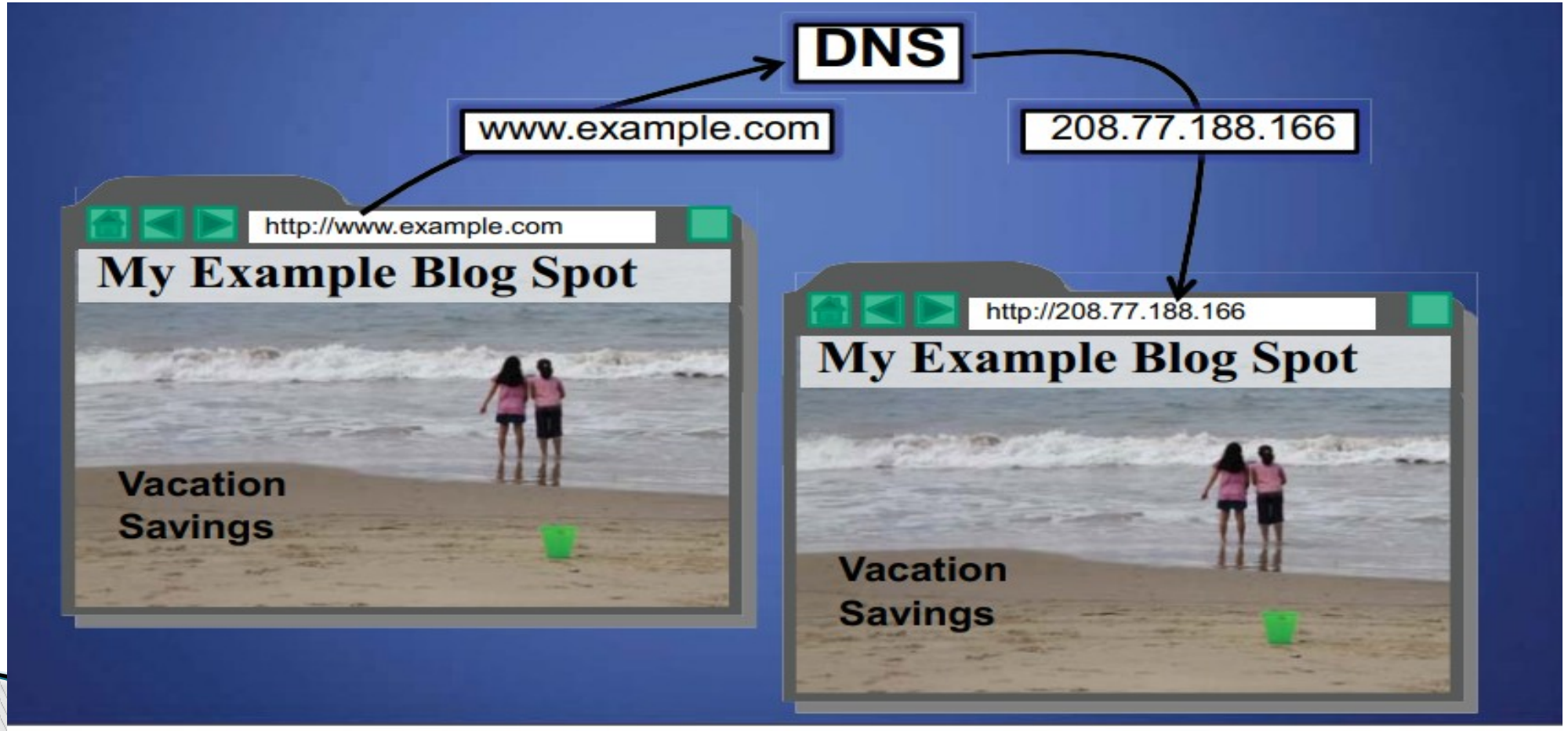
Q: How to map between IP addresses and name ?

Domain Name System:

- *distributed database* implemented in hierarchy of many *name servers*

Domain Name System

•The domain name system (DNS) is an application-layer protocol for mapping domain names to IP addresses



DNS

DNS services

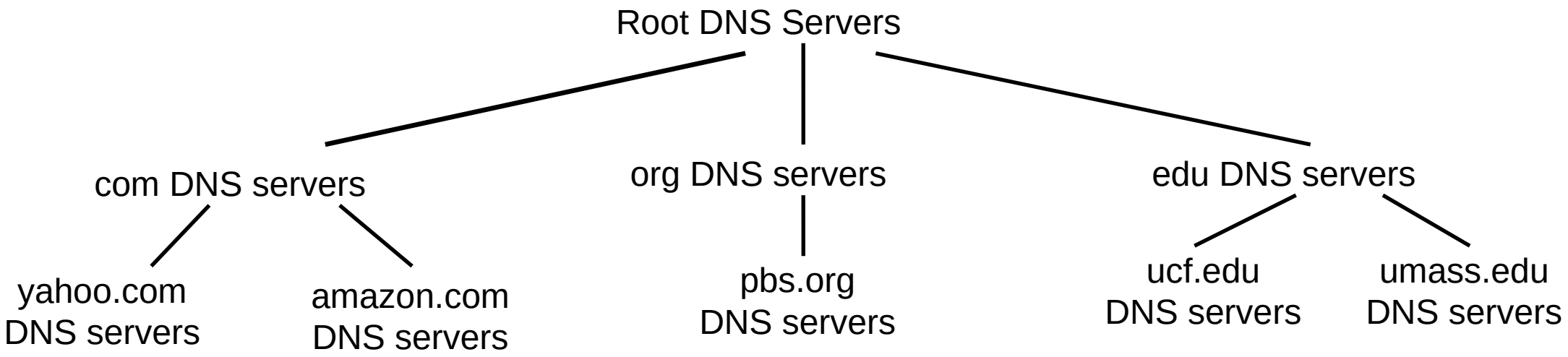
- Hostname to IP address translation
- Host aliasing
  - Canonical and alias names
  - Many names for a single host
- Mail server aliasing
- Load distribution
  - Replicated Web servers: set of IP addresses for one canonical name

Why not centralize DNS?

- single point of failure
- traffic volume
- distant centralized database
- maintenance

doesn't *scale!*

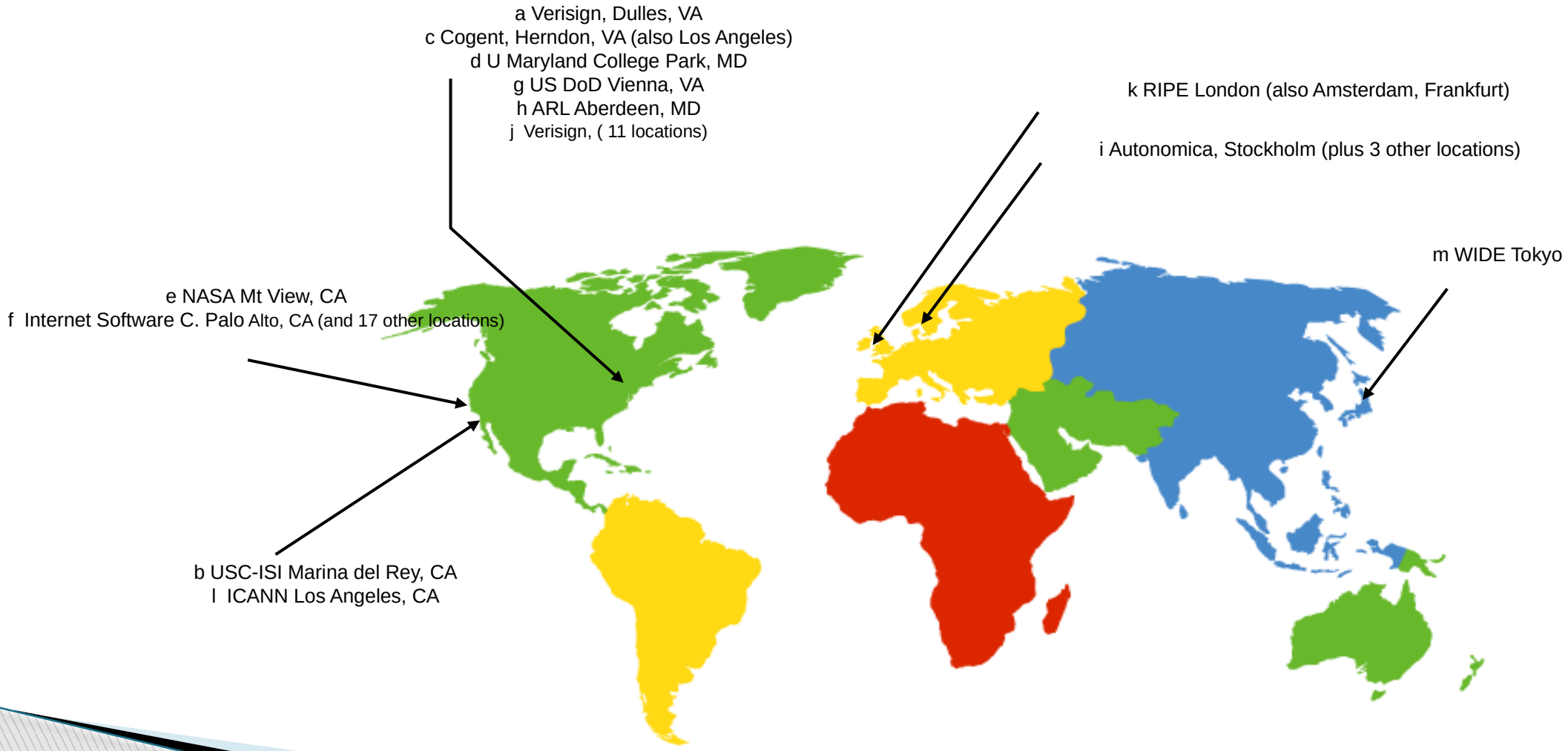
Distributed, Hierarchical Database



Client wants IP for www.amazon.com; 1st approx:

- Client queries a root server to find com DNS server
- Client queries “com” DNS server to get amazon.com DNS server
- Client queries amazon.com DNS server to get IP address for www.amazon.com

Root Name servers



TLD and Authoritative Servers

- Top-level domain (TLD) servers: responsible for com, org, net, edu, etc, and all top-level country domains uk, fr, ca, jp.
  - Network solutions maintains servers for com TLD
  - Educause for edu TLD

- Authoritative DNS servers: organization's DNS servers, providing authoritative hostname to IP mappings for organization's servers (e.g., Web and mail).
  - Can be maintained by organization or service provider (paid by the organization)

Name Servers

- Hierarchy of authoritative name servers
  - Information about root domain
  - Information about its subdomains (A records) or references to other name servers (NS records)
- The authoritative name server hierarchy matches the domain hierarchy: root servers point to DNS servers for TLDs, etc.
- Root servers, and servers for TLDs change infrequently
- DNS servers refer to other DNS servers by name, not by IP: sometimes must bootstrap by providing an IP along with

Local Name Server

- Does not strictly belong to hierarchy
- Each ISP (residential ISP, company, university) has one
  - Also called “default name server”
- When a host makes a DNS query, query is sent to its local DNS server
  - Acts as a proxy (cache), forwards query into hierarchy

Domain Name System

•DNS provides a distributed database over the internet that stores various resource records, including:

- Address (A) record: IP address associated with a host name
- Mail exchange(MX) record: mail server of a domain
- Name server (NS) record: authoritative server for a domain

For example, if example.com wishes to sub-delegate "john.example.com." to John who works at Example, inc., lines like this can be added to the example.com zone file:

```
john.example.com. NS ns1.john.example.com.
john.example.com. NS ns2.john.example.com.
# It's important to provide "glue"; in other words, let the world know
# the IPs for these name servers.
ns1.john.example.com. 10.9.8.7
ns2.john.example.com. 10.5.77.65
```

John, who is running is own nameservers with the IPs 10.9.8.7 and 10.5.77.65 then has a zone file for john.example.com. that looks something like this:

```
# It is best if the NS records for a subzone agree with the delegation
# records above
john.example.com. NS ns1.john.example.com.
john.example.com. NS ns2.john.example.com.

ns1.john.example.com. 10.9.8.7
ns2.john.example.com. 10.5.77.65

# Now that that is out of the way, here is the rest of the zone
john.example.com. 10.9.8.7
www.john.example.com. 10.5.77.65
john.example.com. MX 10 mail.john.example.com.
mail.john.example.com. 10.9.8.7
```

Example DNS entries from http://www.maradns.org/tutorial/recordtypes.html

DNS records

DNS: distributed db storing Resource Records (RR)

RR format: `(name, value, type, ttl)`

Type=A

- `name` is hostname
- `value` is IP address

Type=NS

- **`name`** is domain (e.g. foo.com)
- **`value`** is IP address of authoritative DNS server for this domain

Type=CNAME

- `name` is alias name for some "canonical" (the real) name

`www.ibm.com` is really `servereast.backup2.ibm.com`

- `value` is canonical name

Type=MX

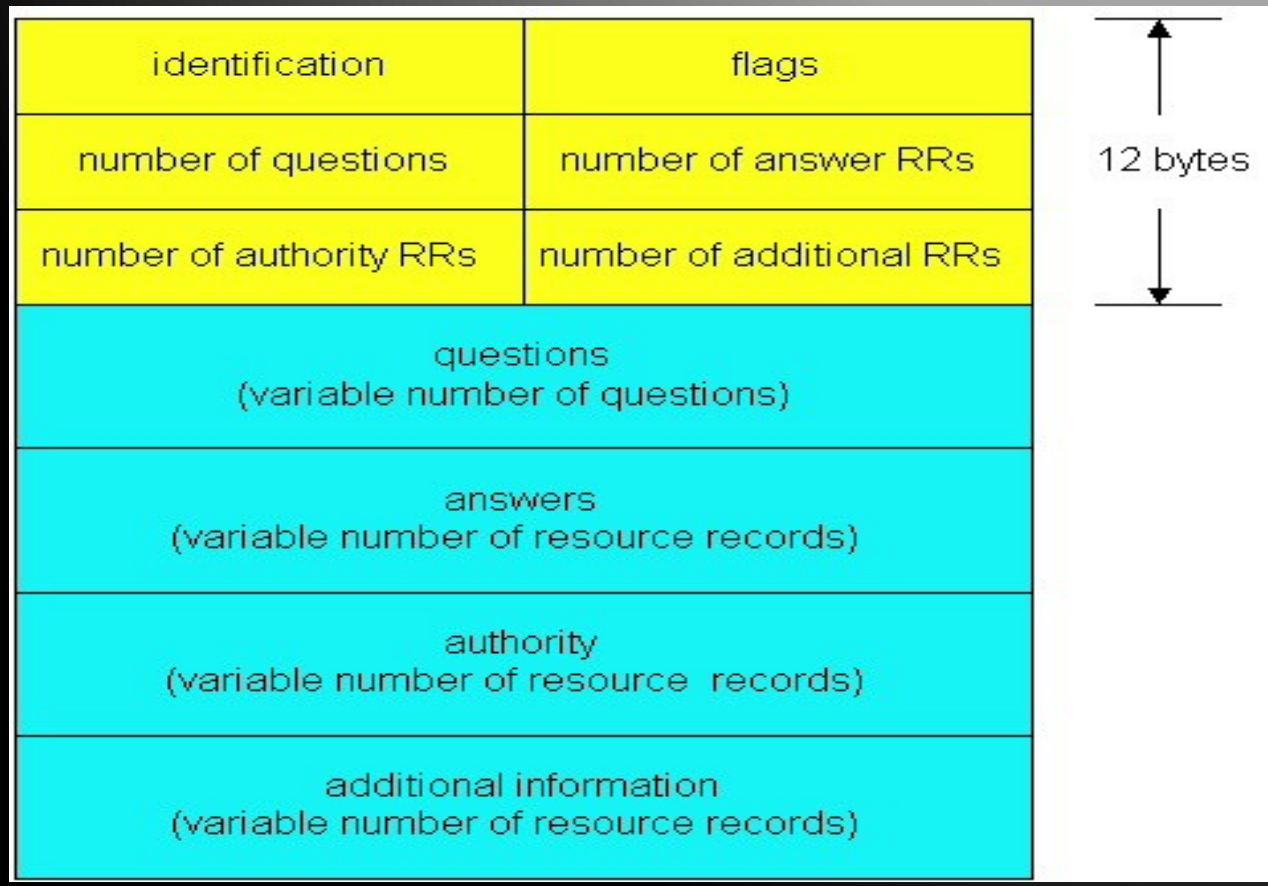
- `value` is name of mailserver associated with name

DNS protocol, messages

DNS protocol : *query* and *reply* messages, both with same *message format*

msg header

- identification: 16 bit # for query, reply to query uses same #
- flags:
  - query or reply
  - recursion desired
  - recursion available
  - reply is authoritative



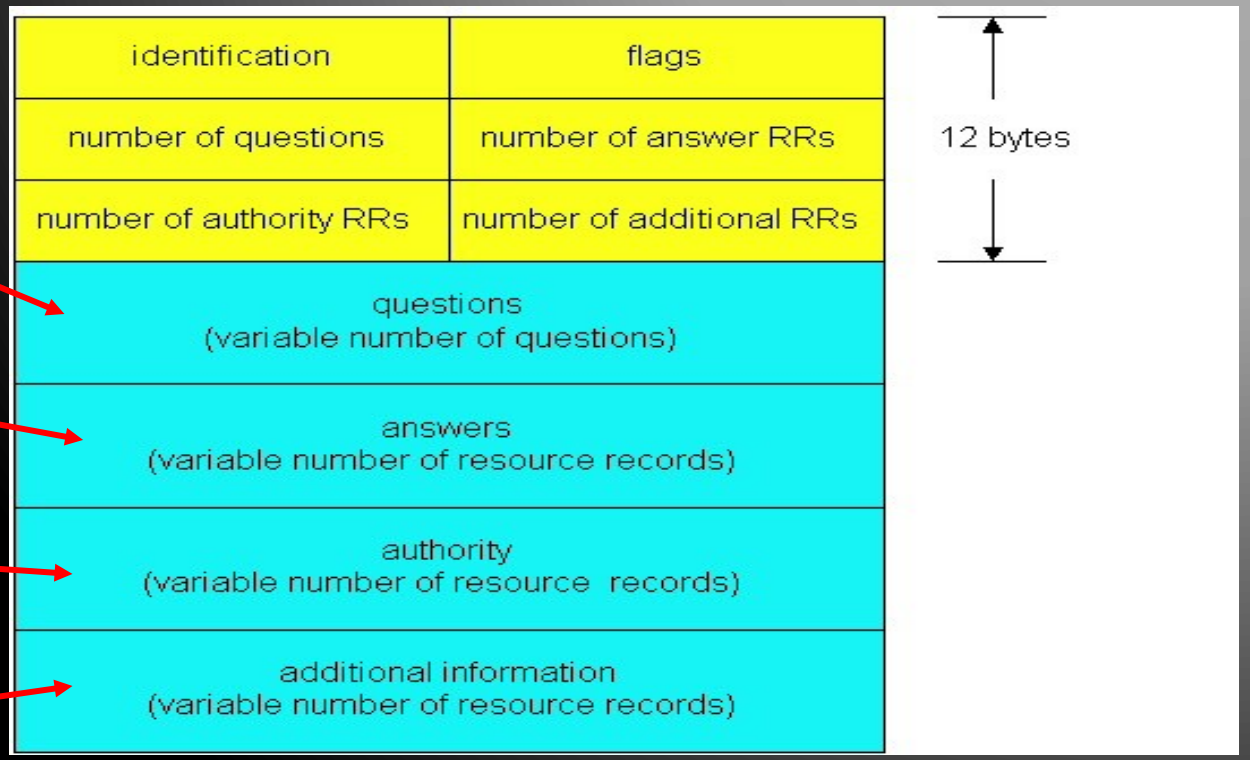
DNS protocol, messages (UDP 53)

Name, type fields for a query

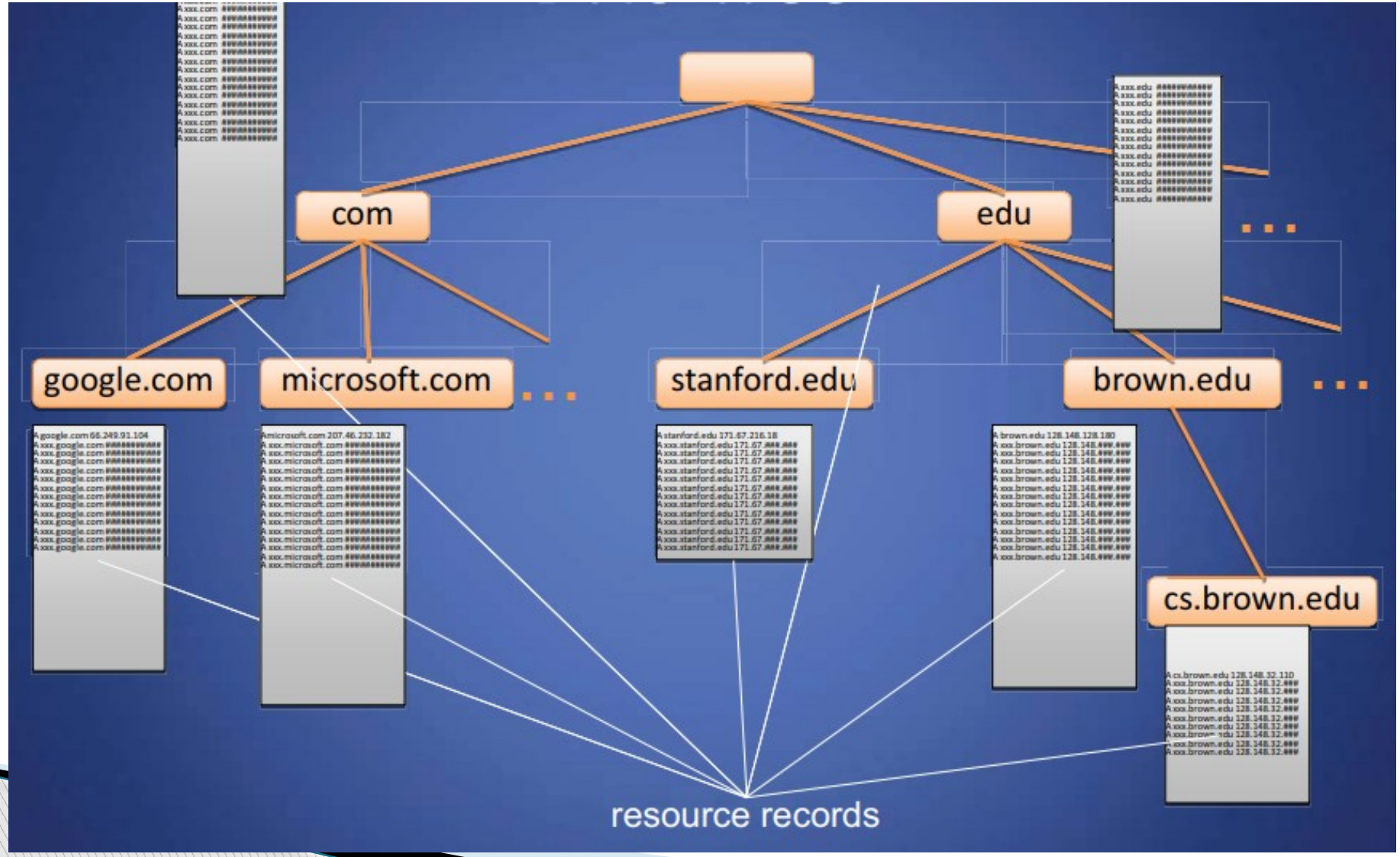
RRs in response to query

records for authoritative servers

additional "helpful" info that may be used



DNS Tree


com
edu
google.com
microsoft.com
stanford.edu
brown.edu
cs.brown.edu
resource records

Namespace Management

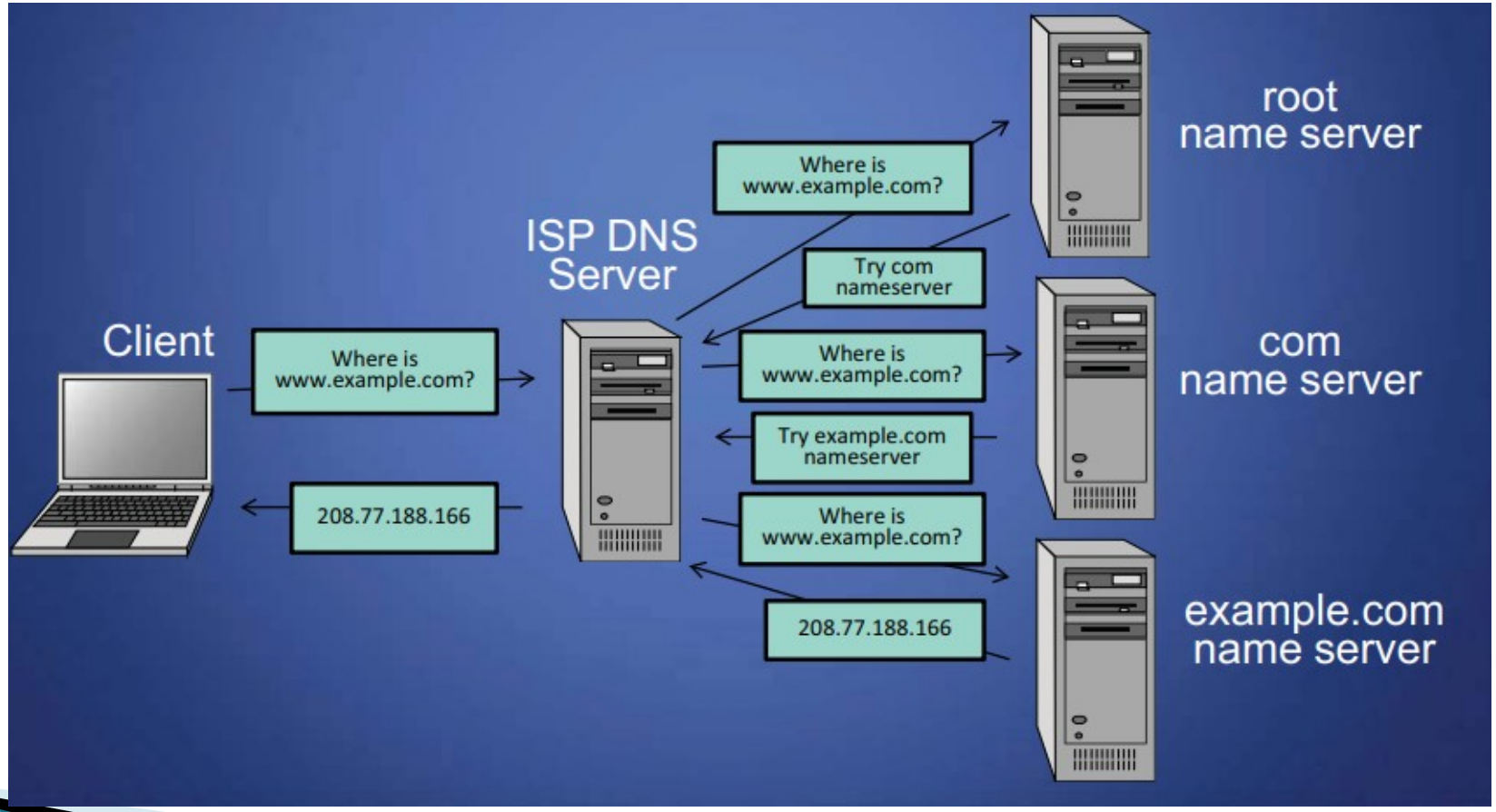
- ICANN: Internet Corporation for Assigned Names and Numbers
- ICANN has the overall responsibility for managing DNS. It controls the root domain, delegating control over each top-level domain to a domain name registry
- Along with a small set of general TLDs, every country has its own TLD -- (cTLDS) – controlled by the government.
- ICANN is the governing body for all general TLDs
- Until 1999 all .com, .net and .org registries were handled by Network Solutions Incorporated.
- After November, 1999, ICANN and NSI had to allow for a shared registration system and there are currently over 500 registrars in the market
- Also since 1999, ICANN has created additional gTLDs including some which are sponsored by consortiums or groups of companies.

Top Level Domains

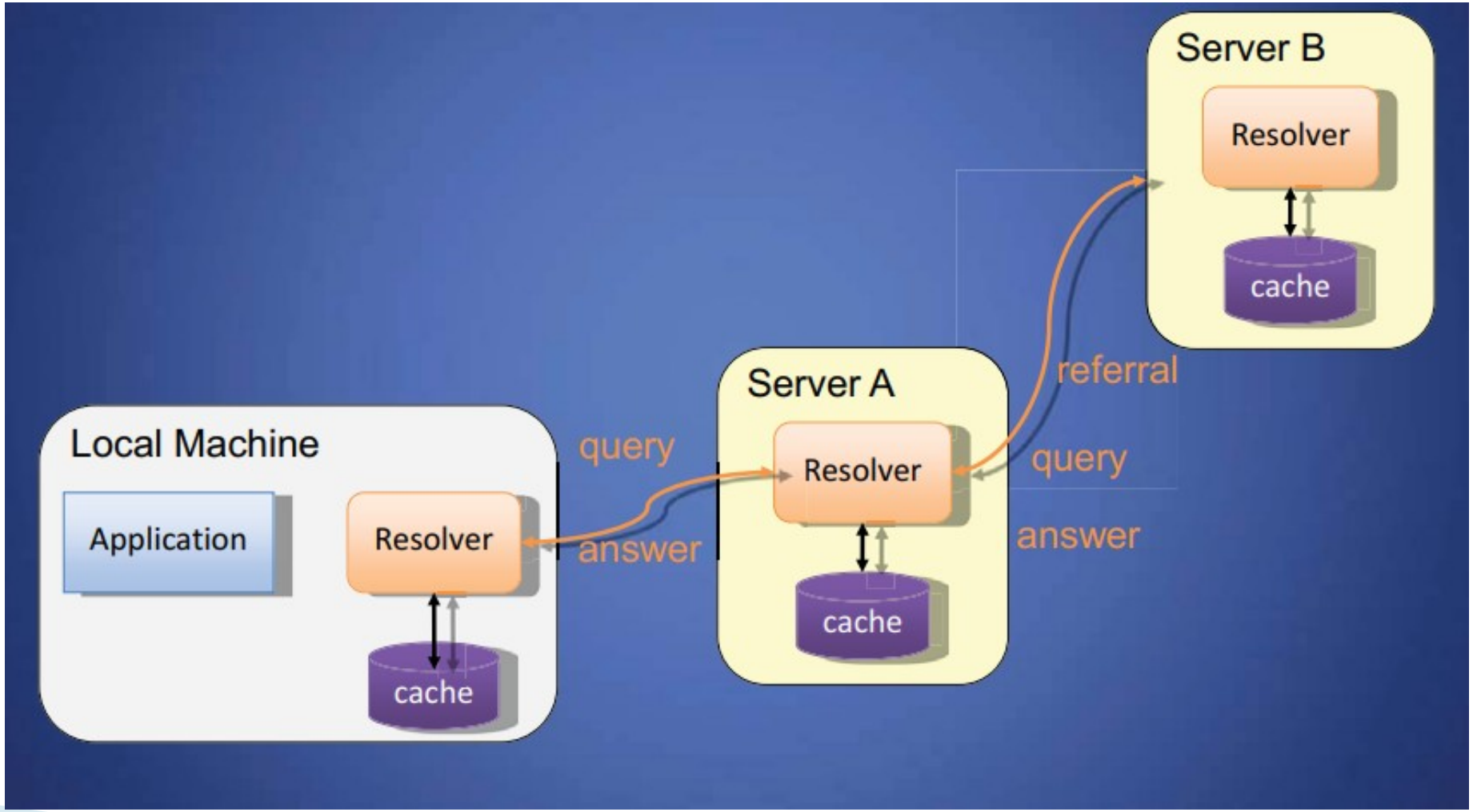
- Started in 1984
- Originally supposed to be named by function
  - .com for commercial websites, .mil for military
- Eventually agreed upon unrestricted TLDs for .com, .net, .org, .info
- In 1994 started allowing country TLDs such as .it, .us
- Tried to move back to hierarchy of purpose in 2000 with creation of .aero, .museum, etc.

Name Resolution

•Zone: collection of connected nodes with the same authoritative DNS server
•Resolution method when answer not in cache:



Recursive Name Resolution



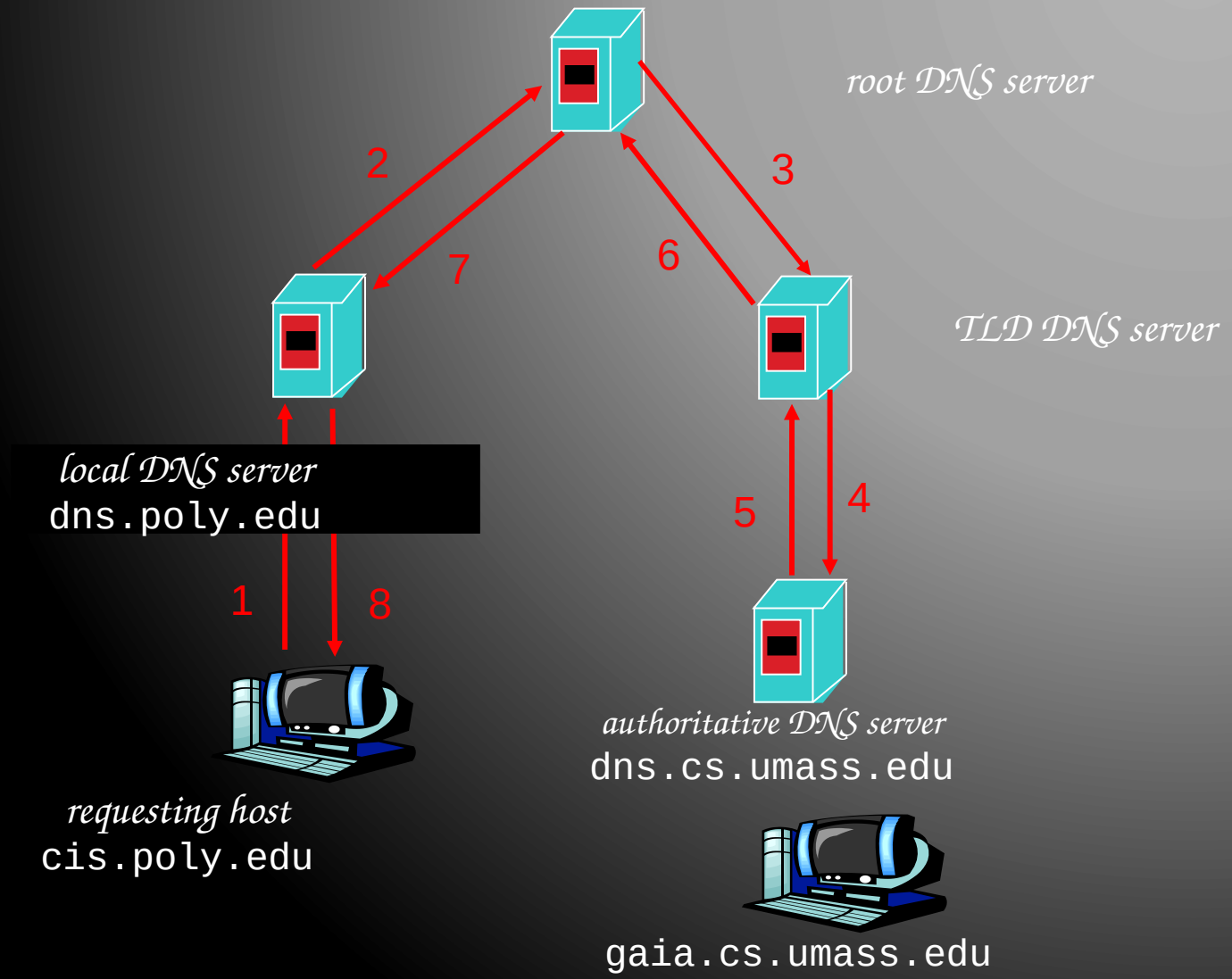
Recursive queries

recursive query:

- DNS client requires DNS server respond with either the requested resource record, or an error message stating that the record or domain name does not exist.

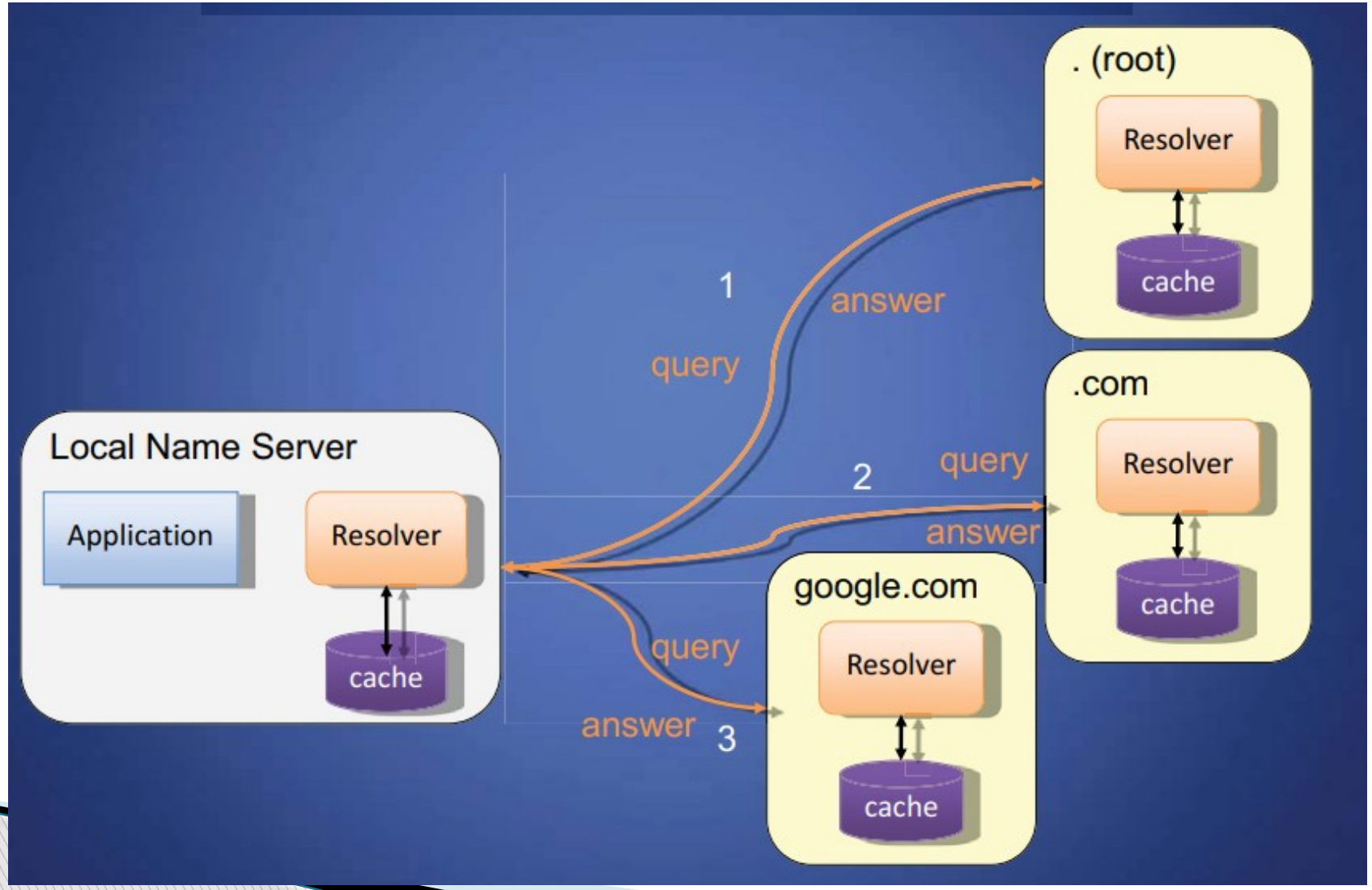
iterative query:

- contacted server replies with name of server to contact
- "I don't know this name, but ask this server"



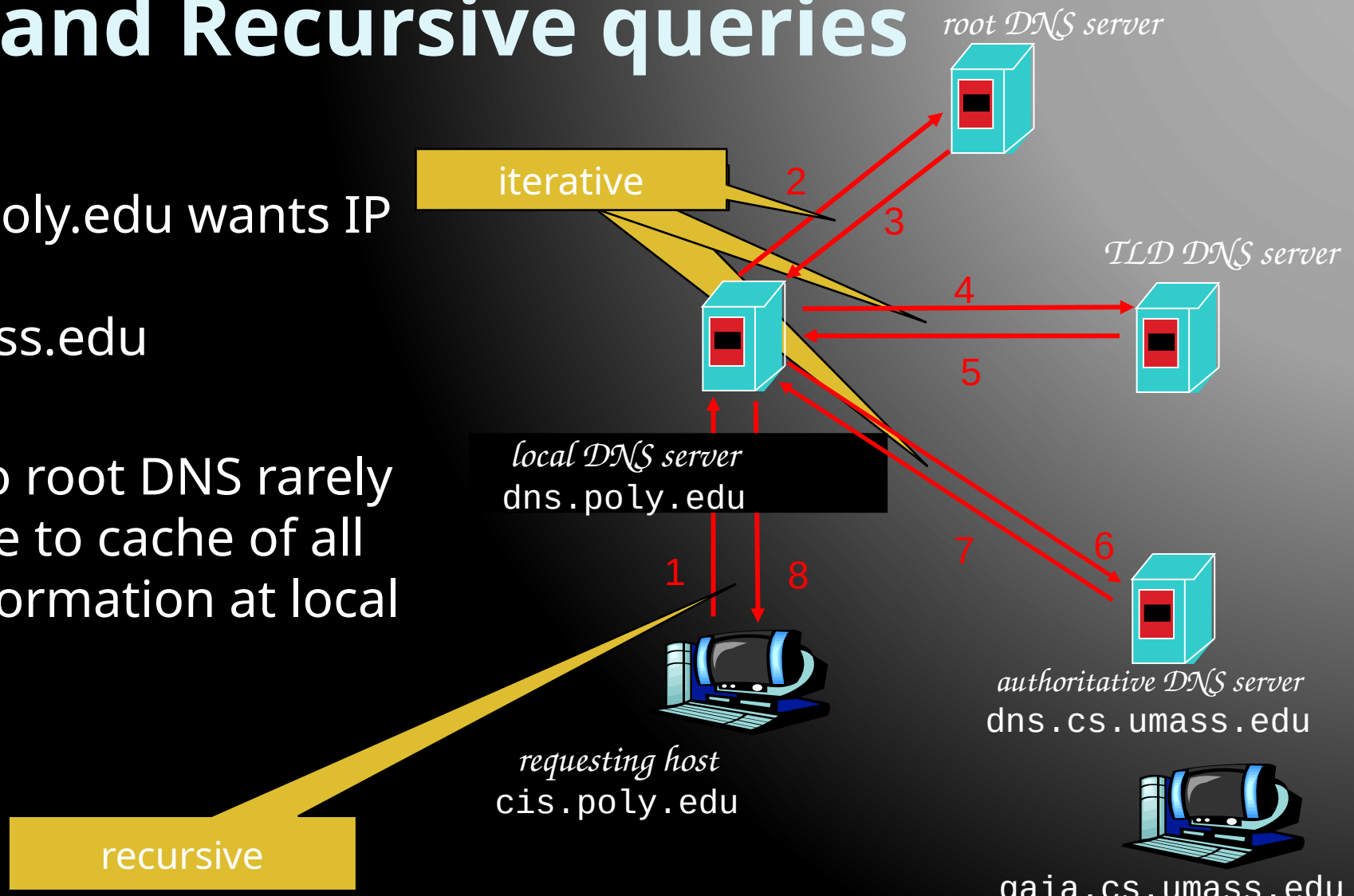
Reference:
http://technet.microsoft.com/en-us/library/cc961401.aspx

Iterative Name Resolution



Iterative and Recursive queries

- Host at cis.poly.edu wants IP address for gaia.cs.umass.edu
- The query to root DNS rarely happens due to cache of all TLD DNS information at local DNS server



Authoritative Name Servers

- Control distributed among authoritative name servers (ANSs)
  - Responsible for specific domains
  - Can designate other ANS for subdomains
- ANS can be master or slave
  - Master contains original zone table
  - Slaves are replicas, automatically updating
- Makes DNS fault tolerant, automatically distributes load
- ANS must be installed as a NS in parents' zone

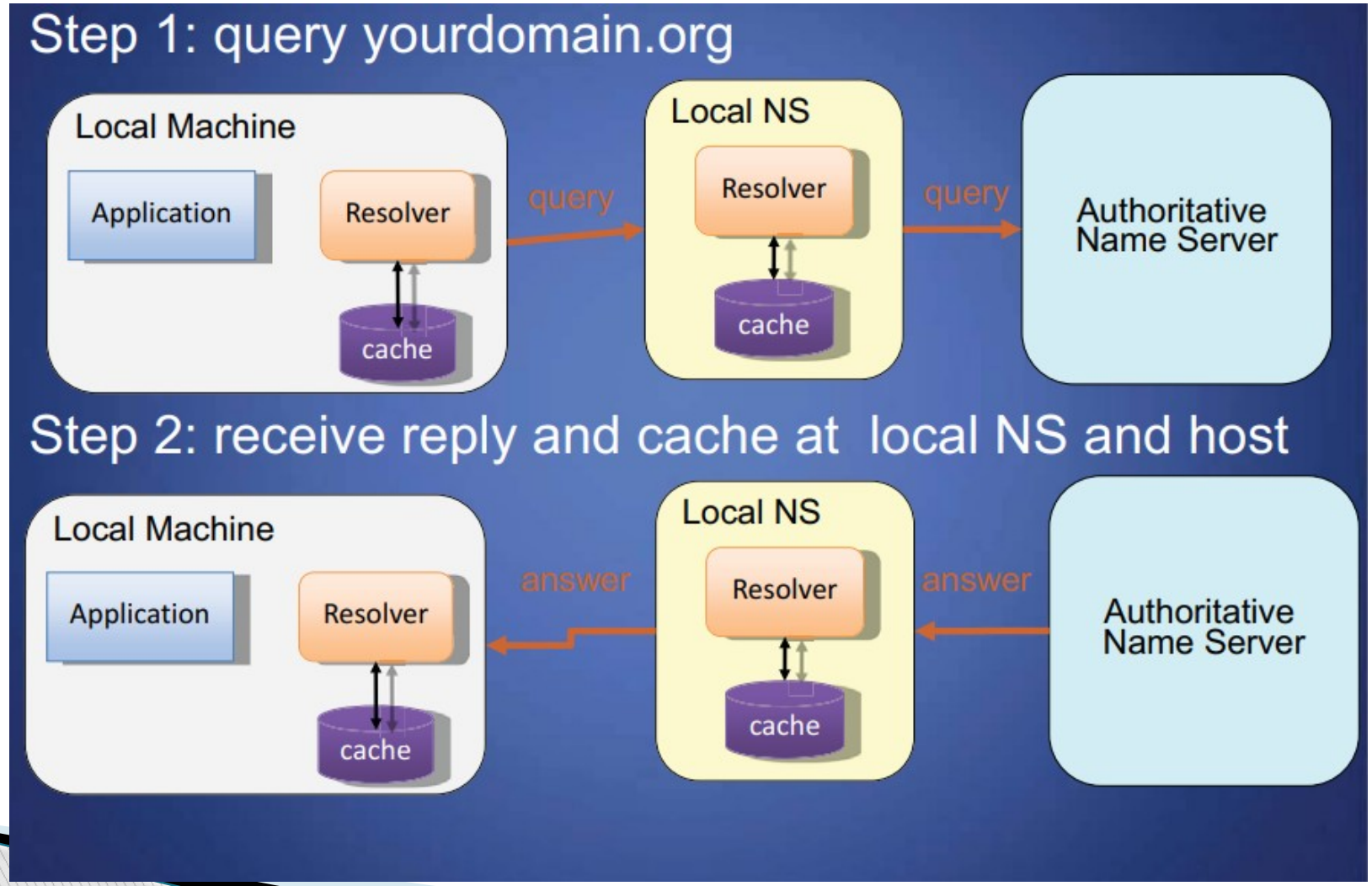
Dynamic Resolution

- Many large providers have more than one authoritative name server for a domain
- Problem: need to locate the instance of domain geographically closest to user
- Proposed solution: include first 3 octets of requester's IP in recursive requests to allow better service
- Content distribution networks already do adaptive DNS routing

DNS Caching

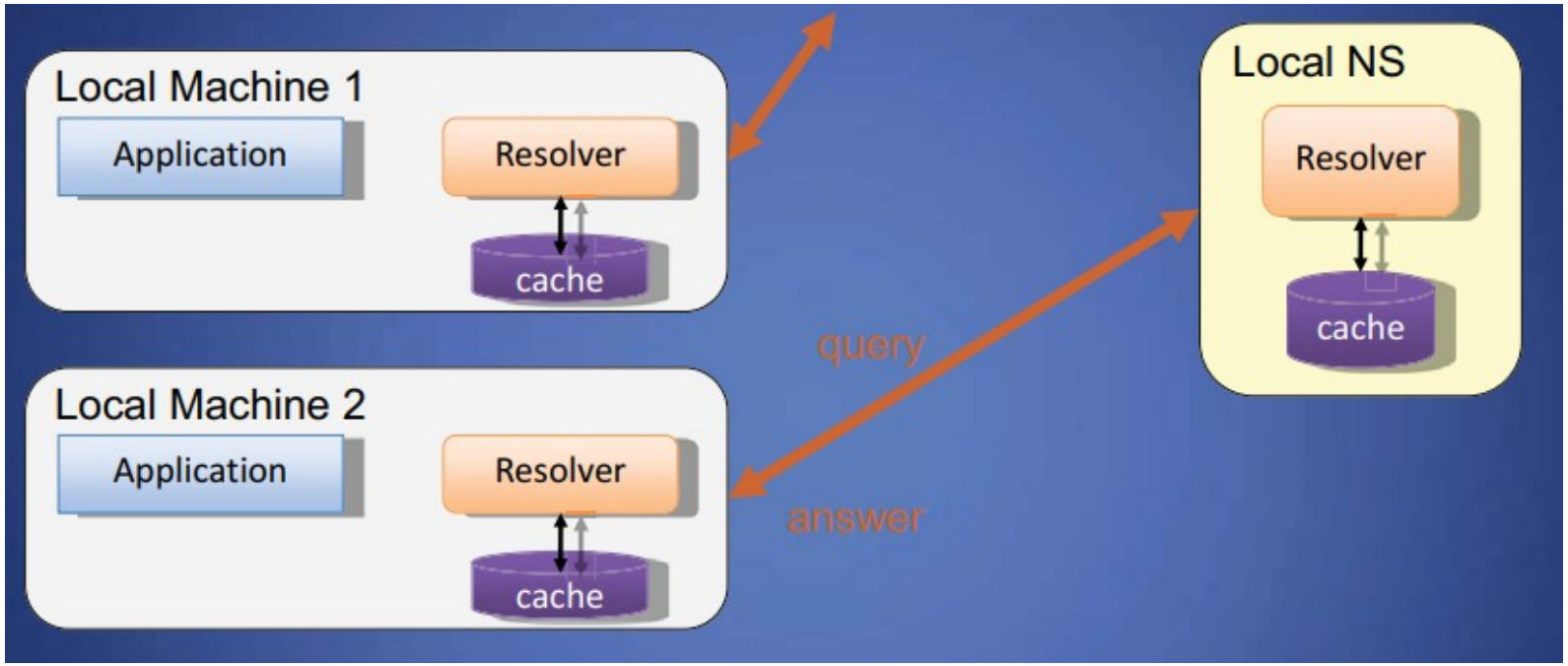
- There would be too much network traffic if a path in the DNS tree would be traversed for each query
  - Root zone would be rapidly overloaded
- DNS servers cache results for a specified amount of time
  - Specified by ANS reply's time-to-live field
- Operating systems and browsers also maintain resolvers and DNS caches
  - View in Windows with command ipconfig /displaydns
  - Associated privacy issues
- DNS queries are typically issued over UDP on port 53
  - 16-bit request identifier in payload

DNS Caching


Step 1: query yourdomain.org
Local Machine
Application
Resolver
cache
query
Local NS
Resolver
cache
query
Authoritative Name Server
Step 2: receive reply and cache at local NS and host
Local Machine
Application
Resolver
cache
answer
Local NS
Resolver
cache
answer
Authoritative Name Server

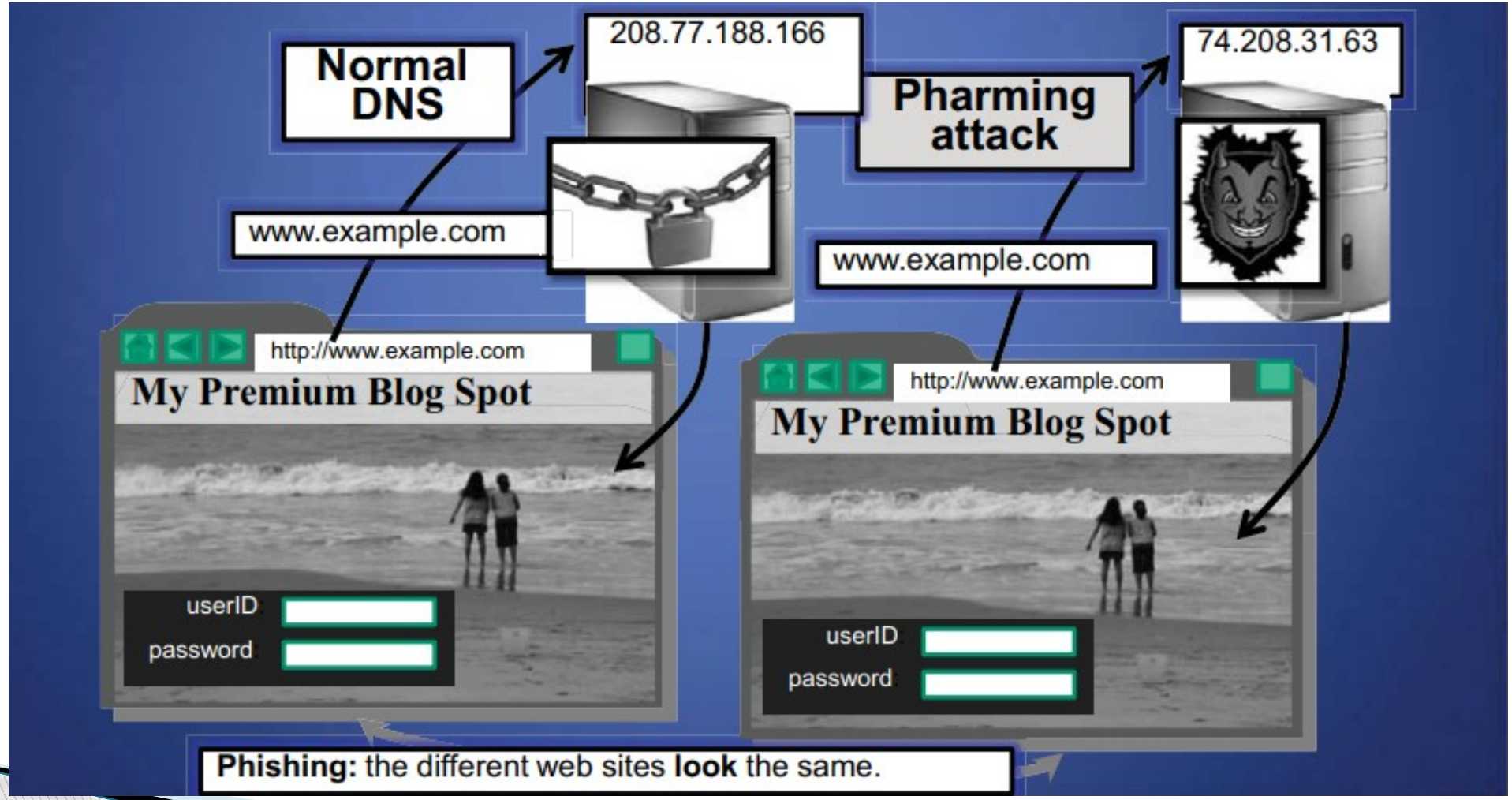
DNS Caching (con'd)

- Step 3: use cached results rather than querying the ANS



- Step 4: Evict cache entries upon ttl expiration

Pharming: DNS Hijacking



DNS Vulnerability

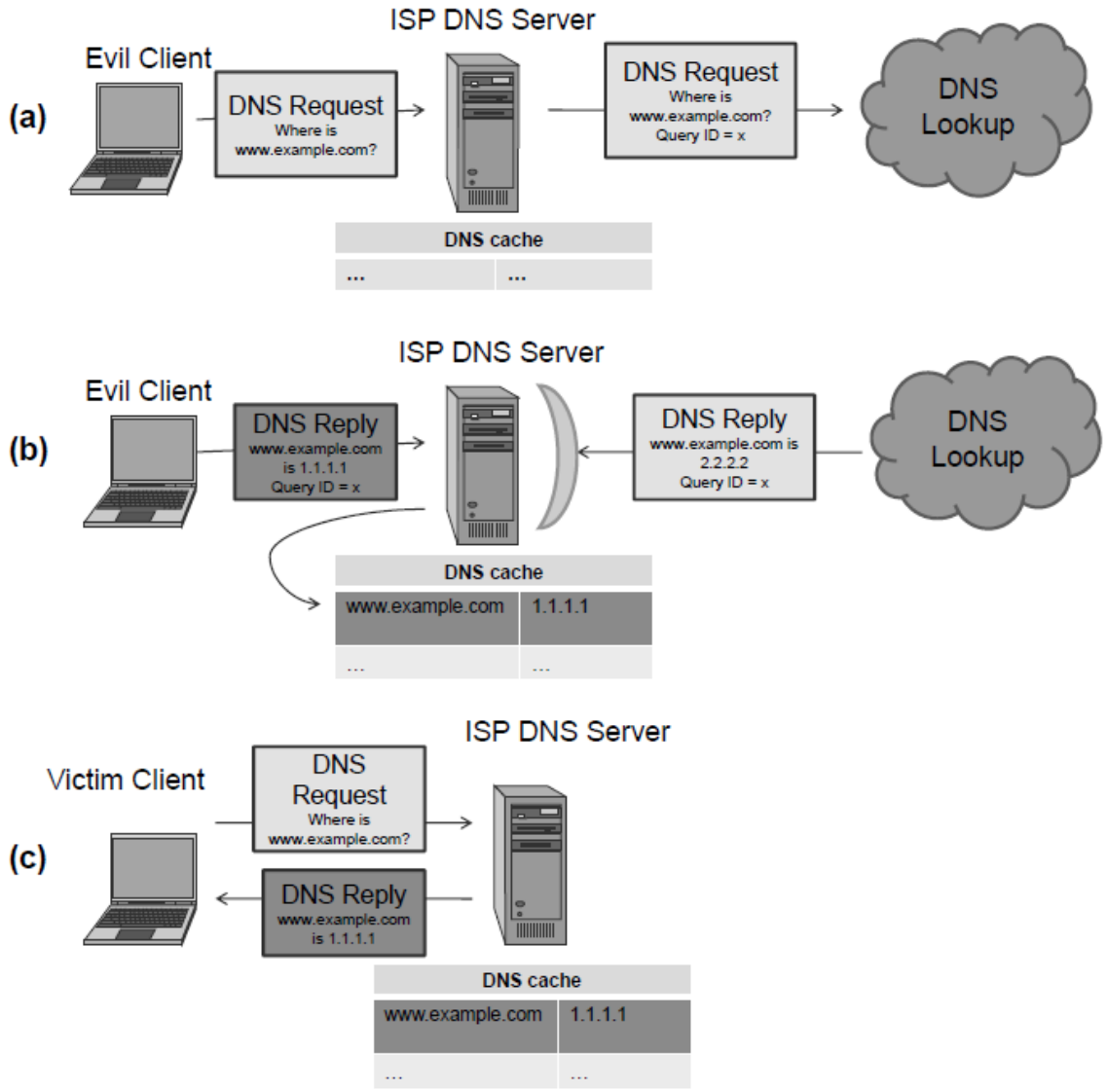
- Most DNS queries and responses are in plaintext
- No authentication is done for DNS response
  - You really has no good way to tell if the DNS response you get are trustable or not!
- DNS is mostly relying on UDP packets
  - IP address spoofing is very easy for UDP packets
    - No seq/ack numbers

DNS Cache Poisoning

- Basic idea: give DNS servers false records and get it cached
- DNS uses a 16-bit request identifier to pair queries with answers
- Cache may be poisoned when a name server:
  - Disregards identifiers
  - Has predictable ids
  - Accepts unsolicited DNS records

DNS Cache Poisoning

- The attacker sends a corresponding reply for his own request, guessing the transaction ID.
- If he successfully guesses the random query ID chosen by the ISP DNS server, the response will be cached.



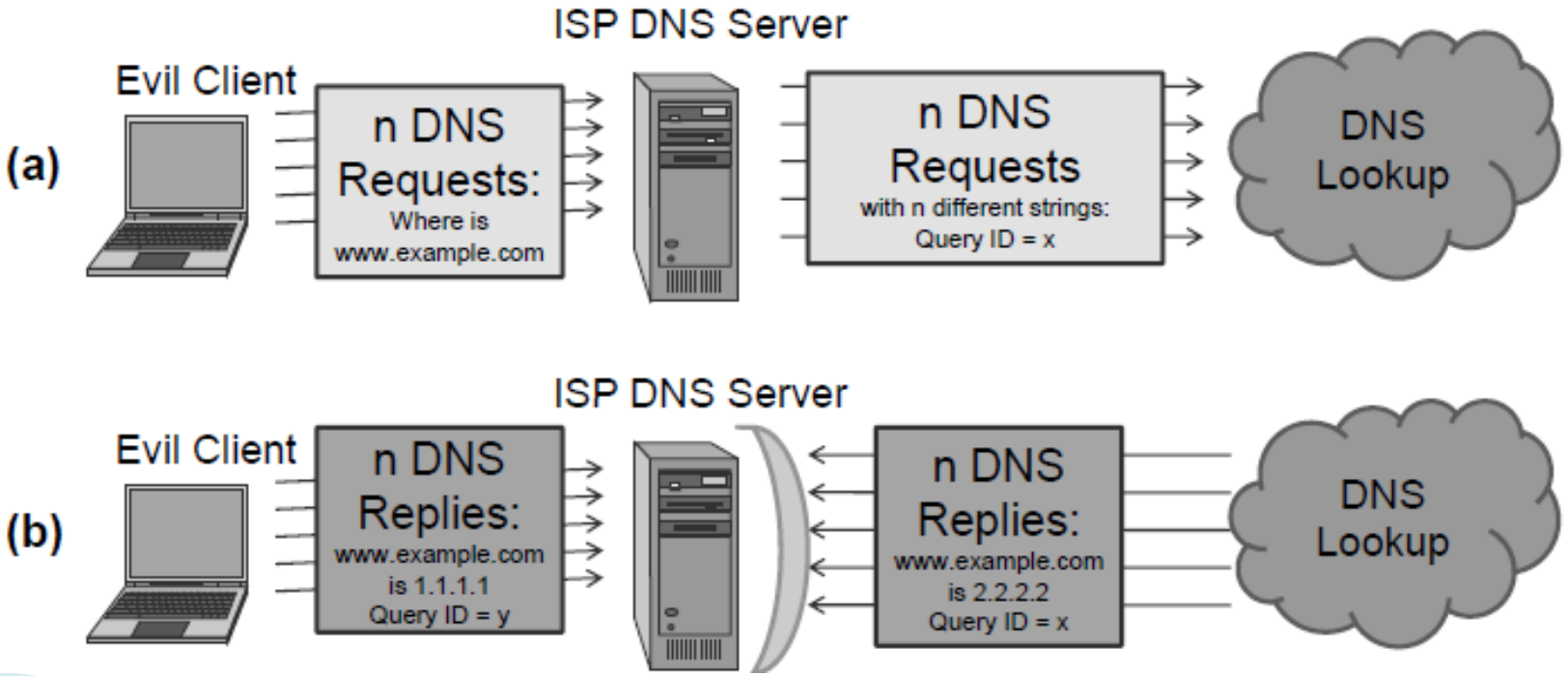
DNS Cache Poisoning and the Birthday Paradox

- This increase in attack success probability from an increase in fake requests is a result of a principle known as the birthday paradox
- Birthday paradox: Probability of two or more people in a group of 23 sharing the same birthday is greater than 50%.
- In a group of 23 people, there are actually 23x22/2 = 253 pairs of birthdays, and it only takes one matching pair for the birthday paradox to hold.

Multiple Request to DNS server

(a) First, an attacker sends n DNS requests for the domain she wishes to poison.

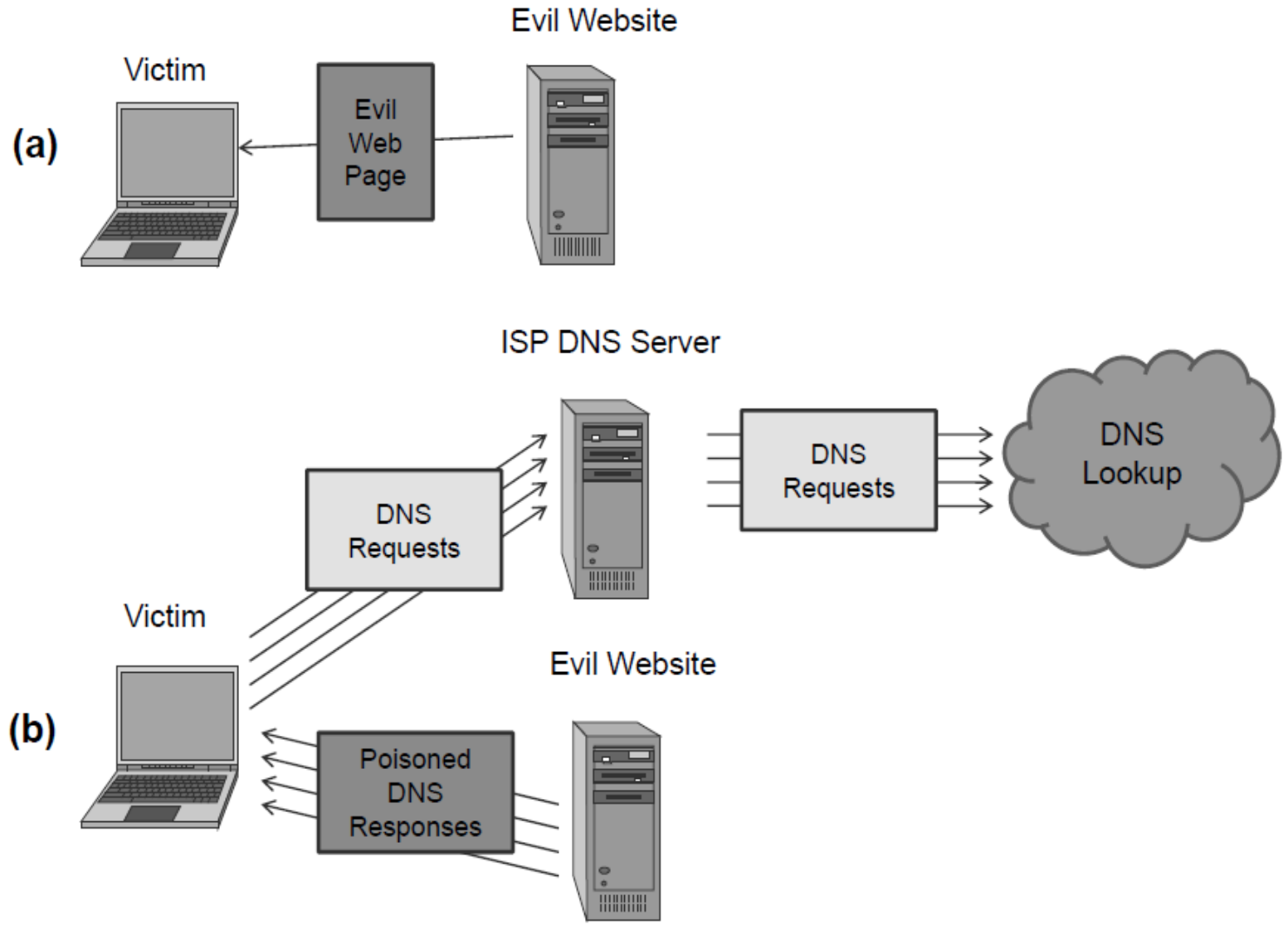
(b) The attacker sends n corresponding replies for her own request. If she successfully guesses one of the random query IDs chosen by the ISP DNS server, the response will be cached.



DNS Cache Poisoning Prevention

- Use random identifiers for queries
- Always check identifiers
- Port randomization for DNS requests
- Deploy DNSSEC
  - Challenging because it is still being deployed and requires reciprocity

Client-Side DNS Cache Poisoning Attacks



Client-Side DNS Cache Poisoning Attacks

- (a) On visiting a malicious web site, the victim views a page containing many images, each causing a separate DNS request to be made to a nonexistent subdomain of the domain that is to be poisoned.
- (b) The malicious web server sends guessed responses to each of these requests. On a successful guess, the client's DNS cache will be poisoned.

Defense Against DNS cache poisoning

- Most DNS poisoning target Local DNS (LDNS) server
- Solution: Configure LDNS to only accept requests from internal networks
  - Why does it need to server outside users?

- Source-port randomization (SPR)
  - DNS query sent out will have two randomized numbers:
    - Source port number (destination port always 53)
    - Query ID number (16 bits)
  - Check DNS response for both of these numbers

Cybersquatting

- To register a domain in anticipation of that domain being desirable to another organization
  - Intent to sell tot hat organization for big profit

- For example, You can register “hurricane2013.com”, or “hurricane-in-Texas.com” if you think there will be a big one in Texas in the near future.
  - Sell it for big profit if it is true!
  - Domain name purchase is cheap!
- Many organizations have to buy all related domain names to prevent cybersquatting

- A legitimate example: http://teaparty.com/
  - suspicious ones for tea party: http://tparty.com/, http://t-party.com/
- http://en.wikipedia.org/wiki/Cybersquatting

Typosquatting

- Register all possible typo domain names for another organization
  - Should a user accidentally enters an incorrect website address, he may be led to an alternative website owned by a cybersquatter.
  - Could lead to phishing attack (malicious), or increase web visits (not very malicious)

- For example, for “bankofamerica.com”, a cybersquatter could register:
  - “bankamerica.com”, “bankoamerica.com”, “bankofamerican.com”, “bankfoamerica.com”, ……
  - Domain name purchase is cheap!

DNSSEC

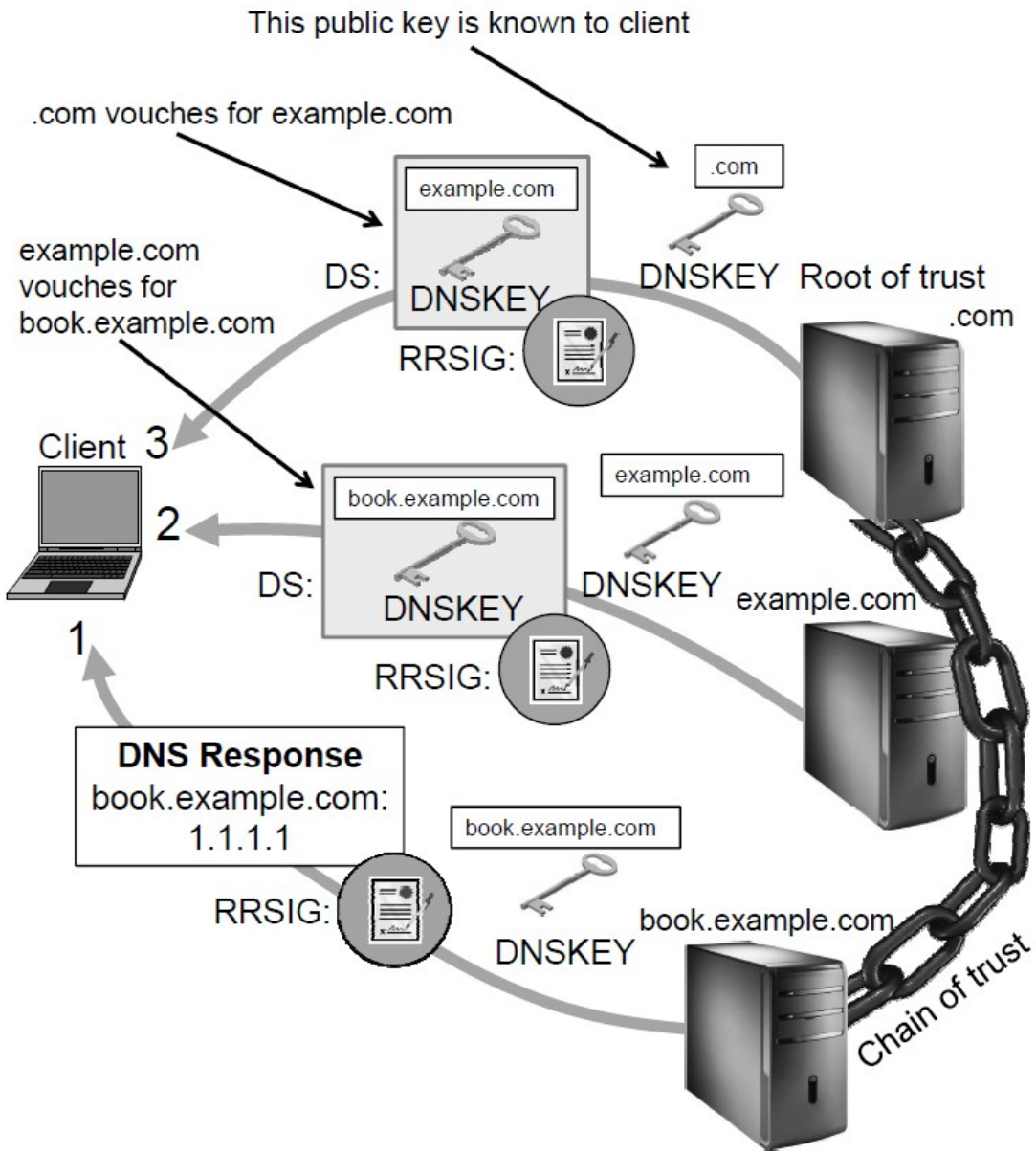
- Guarantees:
  - Authenticity of DNS answer origin
  - Integrity of reply
  - Authenticity of denial of existence
- Accomplishes this by signing DNS replies at each step of the way
- Uses public-key cryptography to sign responses
- Typically use trust anchors, entries in the OS to bootstrap the process

DNSSEC operation

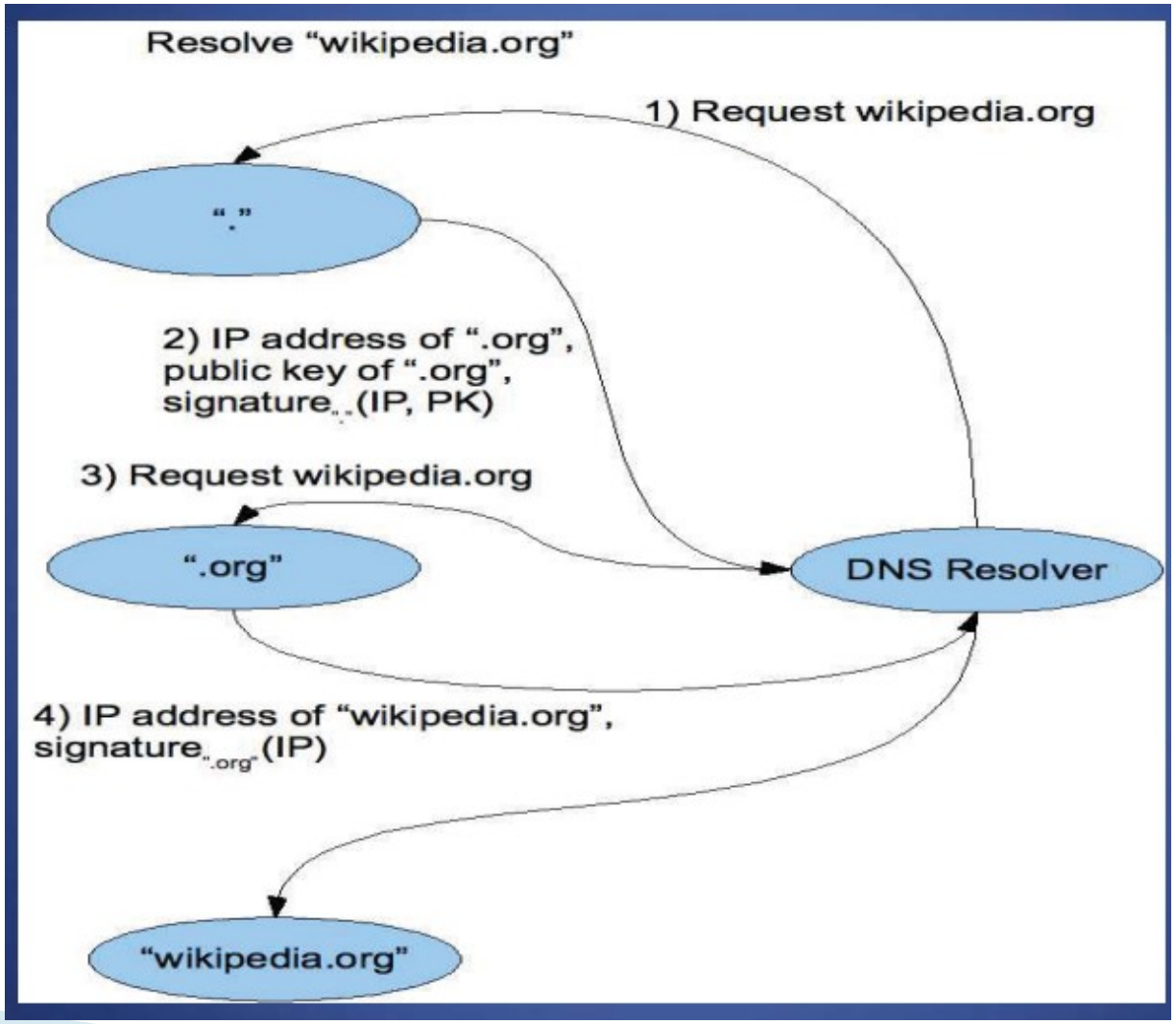
- When a client issues a DNS request, the request packet indicates that DNSSEC is supported.
- If the queried server also supports DNSSEC, then a **resource-record signature** (**RRSIG)** record is returned alongside any resolved queries.
- The RRSIG record contains a digital signature of the returned records computed by generating a hash of the returned records and encrypting this hash with the authoritative name server's private key.
- The response to the client contains a **DNSKEY record** containing the public key of the ANS.
- The client can then verify the authenticity of the returned records by decrypting the digital signature using the name server's public key and comparing the hash to a locally computed hash of the records.

DNSSEC operation

- Ensures source authentication of the DNS reply message through digital signature



DNS Signing


Resolve “wikipedia.org”
1) Request wikipedia.org
“.”
2) IP address of “.org”,
public key of “.org”,
signature.(IP, PK)
3) Request wikipedia.org
“.org”
DNS Resolver
4) IP address of “wikipedia.org”,
signature.org(IP)
“wikipedia.org”

DNSSEC Deployment

- As the internet becomes regarded as critical infrastructure there is a push to secure DNS
- NIST is in the process of deploying it on root servers now

- May add considerable load to dns servers with packet sizes considerably larger than 512 byte size of UDP packets

- There are political concerns with the US controlling the root level of DNS